

【中间件安全】Nginx 安全加固规范 - 微信公众号Bypass

版权声明：本文由Bypass原创发布，转载请保留出处。欢迎关注我的个人微信公众号：Bypass--，浏览更多精彩文章。 https://blog.csdn.net/qq_23936389/article/details/85013923

1. 适用情况

适用于使用Nginx进行部署的Web网站。

2. 技能要求

熟悉Nginx配置，能够Nginx进行部署，并能针对站点使用Nginx进行安全加固。

3. 前置条件

- 1、根据站点开放端口，进程ID，确认站点采用Nginx进行部署；
- 2、找到Nginx安装目录，针对具体站点对配置文件进行修改；
- 3、在执行过程中若有任何疑问或建议，应及时反馈。

4. 详细操作

4.1 日志配置

- 1、备份nginx.conf 配置文件。

修改配置，按如下设置日志记录文件、记录内容、记录格式，添加标签为main的log_format格式

```
1. (http标签内，在所有的server标签内可以调用)：
2. log_format main '$remote_addr - $remote_user [$time_local] "$request" '
3. '$status $body_bytes_sent "$http_referer" '
4. '$http_user_agent' "$http_x_forwarded_for" ;
```

- 2、在server标签内，定义日志路径

```
access_log logs/host.access.log main
```

- 3、保存，然后后重启nginx服务。

4.2 禁止目录浏览

备份nginx.conf配置文件。

编辑配置文件，HTTP模块添加如下一行内容：

```
autoindex off;
```

保存，然后后重启nginx服务。

4.3 限制目录执行权限

备份nginx.conf配置文件。

编辑配置文件，在server标签内添加如下内容：

```
1. #示例：去掉单个目录的PHP执行权限
2. location ~ /attachments/.*\.(php|php5)?$ {
3. deny all;
4. }
5. #示例：去掉多个目录的PHP执行权限
6. location ~
7. /(attachments|upload)/.*\.(php|php5)?$ {
8. deny all;
9. }
```

保存，然后后重启nginx服务。

需要注意两点：

- 1、以上的配置文件代码需要放到 location ~ .php{...}上面，如果放到下面是无效的;
- 2、attachments需要写相对路径，不能写绝对路径。

4.4 错误页面重定向

备份nginx.conf配置文件。

修改配置，在http{}段加入如下内容

```
1. http {
2. ...
3. fastcgi_intercept_errors on;
4. error_page 401 /401.html;
5. error_page 402 /402.html;
6. error_page 403 /403.html;
7. error_page 404 /404.html;
8. error_page 405 /405.html;
9. error_page 500 /500.html;
10. ...
```

11. }
12. 修改内容：
13. ErrorDocument 400 /custom400.html
14. ErrorDocument 401 /custom401.html
15. ErrorDocument 403 /custom403.html
16. ErrorDocument 404 /custom404.html
17. ErrorDocument 405 /custom405.html
18. ErrorDocument 500 /custom500.html
19. 其中401.html、402.html、403.html、404.html、405.html、500.html 为要指定的错误提示页面。

保存，重启 nginx 服务生效

4.5 最佳经验实践

4.5.1 隐藏版本信息

备份nginx.conf配置文件。

编辑配置文件，添加http模块中如下一行内容：

```
server_tokens off;
```

保存，然后后重启nginx服务。

4.5.2 限制HTTP请求方法

备份nginx.conf配置文件。

编辑配置文件，添加如下内容：

```
1. if ($request_method !~ ^(GET|HEAD|POST)$ ) {  
2. return 444;  
3. }
```

保存，然后后重启nginx服务。

备注：只允许常用的GET和POST方法，顶多再加一个HEAD方法

4.5.3 限制IP访问

备份nginx.conf配置文件。

编辑配置文件，在server标签内添加如下内容：

```
1. location / {  
2. deny 192.168.1.1; #拒绝IP  
3. allow 192.168.1.0/24; #允许IP
```

```
4. allow 10.1.1.0/16; #允许IP
5. deny all; #拒绝其他所有IP
6. }
```

保存，然后后重启nginx服务。

4.5.4 限制并发和速度

备份nginx.conf配置文件。

编辑配置文件，在server标签内添加如下内容：

```
1. limit_zone one $binary_remote_addr 10m;
2. server
3. {
4.     listen    80;
5.     server_name down.test.com;
6.     index index.html index.htm index.php;
7.     root /usr/local/www;
8.     #Zone limit;
9.     location / {
10.         limit_conn one 1;
11.         limit_rate 20k;
12.     }
13. ....
14. }
```

保存，然后后重启nginx服务。

4.5.5 控制超时时间

备份nginx.conf配置文件。

编辑配置文件，具体设置如下：

```
1. client_body_timeout 10; #设置客户端请求主体读取超时时间
2. client_header_timeout 10; #设置客户端请求头读取超时时间
3. keepalive_timeout 5 5; #第一个参数指定客户端连接保持活动的超时时间，第二个参数是可选的，它指定了消息头保持活动的有效时间
4. send_timeout 10; #指定响应客户端的超时时间
```

保存，然后后重启nginx服务。

4.6 风险操作项

4.6.1 Nginx降权

备份nginx.conf配置文件。

编辑配置文件，添加如下一行内容：

```
user nobody;
```

保存，然后后重启nginx服务。

4.6.2 防盗链

备份nginx.conf配置文件。

编辑配置文件，在server标签内添加如下内容：

```
1. location ~* ^.+\.(gif|jpg|png|swf|flv|rar|zip)$ {  
2.     valid_referers none blocked server_names *.nsfocus.com http://localhost baidu.com;  
3.     if ($invalid_referer) {  
4.         rewrite ^/ [img]http://www.XXX.com/images/default/logo.gif[/img];  
5.         # return 403;  
6.     }  
7. }
```

保存，然后后重启nginx服务。

4.6.3 补丁更新

1、软件信息

1. 查看软件版本 `nginx -v`
2. 测试配置文件 `nginx -t`

2、补丁安装

手动安装补丁或安装最新版本软件

最后

欢迎关注个人[微信公众号](#)：Bypass--，每周原创一篇技术干货。

